CoSeal：面向 AI 代理多级委托、先查授权再签名的 SM2 两方协同签名

【待填：作者与单位；若复赛要求匿名则删去】

写作指引：标题的两个备选：（1）当前标题；（2）“基于授权检查条件协同 SM2 签名的 AI 代理委托执行与支付授权”。标题应与已实现的 $n = 2$ 协同签名范围一致。

摘要

写作指引：摘要按“问题—方法—实现—结果—边界”写。下面已按实测结果写好初稿，C 可以润色，但数字不能改，除非重新测量。“实现了”只用于已实现部分；撤销名单快照只能写成“设计”。

大模型 AI 代理（智能体）以委托方式代用户调用工具和发起支付时，授权检查通常集中在单一网关或授权服务器：一旦该组件的签名密钥或逻辑被攻破，任务边界、撤销和预算约束随之失效；受提示注入影响的 AI 代理也可能尝试越权执行。本文以 CoSeal（共印）实现“先查授权再签名”机制：把执行凭据的 SM2 签名密钥以两方协同方式分布于**授权侧签名方**与**网关侧签名方**，授权侧签名方仅在独立核验委托链、撤销状态与剩余预算等授权检查条件成立后才参与签名；输出是标准 SM2 签名，可由任何符合 GB/T 32918 的实现直接验证，并同时用作网关执行凭据、下游效果端凭据与支付意图批准。我们在 OAuth 委托授权与国密持有者证明系统上实现了两方原型，密钥由两方交互生成、无需可信分发者；在半诚实模型下论证了任一单方被攻破都无法为未授权行动产生有效凭据。在多个 AI 代理协同采购场景中，9 类攻击均在预期位置被拒绝且未产生业务效果；在仿真环境下，协同签名三轮计算的中位耗时为 15.9 ms，含授权检查条件核验的授权侧轮次为 26.0 ms（各 $n = 100$）。针对签名之后才发生的撤销，本文进一步给出将 AS 签名的撤销名单快照绑定进签名、使撤销新鲜度可被离线验证的扩展设计，尚未实现。

关键词：协同签名；SM2；委托授权；AI 代理安全；OAuth；撤销实时生效

1 引言

写作指引：共 5 段。第 1 段讲一个具体例子，不讲技术名词；第 2 段讲两个风险；第 3 段讲现有标准和研究已经解决了什么、还缺什么；第 4 段讲本文思路（一句话主张）；最后列贡献。全篇只围绕两条主线：AI 代理越权，以及单点被攻破。预算、恢复、审计在第 4.1作为基础机制介绍，不要在引言里展开。

场景。 用户委托一组 AI 代理完成企业采购：统筹代理拆分任务，选品代理比价，下单代理下单付款。用户批准的是一个有边界的任务（例如“1000 元以内、指定供应商、本周有效”），而不是把账户交给 AI 代理。

两个风险。 第一，AI 代理处理的报价、网页等外部内容可能含有恶意指令，使其提出超出任务边界的操作。第二，即使授权协议本身正确，负责“说可以”的组件——授权服务器（AS）或工具调用网关——也是单点：其签名密钥泄露或逻辑被篡改，所有约束都会失效。

现有方法与缺口。 OAuth 令牌交换 [1] 和发送者约束 [2] 能限制令牌被盗用，委托降权与撤销实时生效可以在应用层实现，但这些检查最终仍由单一组件执行。门限签名能把一个签名能力分散到多方 [13, 14]，近期工作 KITA [15] 将其用于 AI 代理的行动审批，由多个 LLM 评审者审查后释放签名份额。然而，现有审批类方案的签名方依据的是语义判断或静态策略，并不独立核验 OAuth 委托链和撤销状态，而且普遍采用非国密算法。【待填：C 在核对 KITA 原文后，补一句它在撤销/委托链方面的实际情况；不确定就写“未见讨论”】

本文思路。 我们采用**先查授权再签名**机制：执行凭据的 SM2 私钥被拆分在两个独立逻辑边界内的签名方，授权侧签名方只有在亲自确认“此刻这一行动确实被授权”时才交出它那一半签名能力。因此，一个有效签名本身就证明了授权检查条件在签名时成立；这个证明随请求携带，网关、下游订单服务和收款方都能用标准 SM2 验签独立确认。

贡献。

1. **不靠识别攻击。**以委托链、撤销状态和祖先共享预算作确定性检查；代理提出的越权意图须通过网关和签名环节检查（第 4.1 and 4.4）。真实大模型提示注入实验尚未完成。
2. **网关不再独自掌握下单签名。**授权侧核验当前授权后才参与 SM2 两方协同签名，并与受理事务、效果端和付款批准组合（第 4.3 and 4.5 to 4.7）。网关单方不能伪造新的批准；结论限于半诚实、$n = 2$、同主机原型，签名后撤销仍有窗口。
3. **下游采用标准 SM2 验签。**不改模型，输出普通 SM2 签名；完成 16 个集成用例与 552 项数据库回归，并测量阶段开销（第 5 and 7）。当前为 Python 非常数时间原型，不作生产部署保证。

此外，针对“签名之后才发生的撤销”这一剩余窗口，我们给出撤销名单快照的扩展设计（第 4.9），该部分尚未实现。

写作指引：贡献只写这三条，每条结尾都指向对应章节。已有的 OAuth/请求证明/预算/恢复能力在第 4.1作为“基础”介绍，不列为贡献。撤销名单快照只能放在贡献列表之外，明确写“尚未实现”。

2 背景与相关工作

写作指引：每个小节先说别人解决了什么，再说和本文的区别。对别人的方案不确定的地方写“未确认”，不能因为没看到就写成“不支持”。

2.1 OAuth 委托与发送者约束

写作指引：RFC 8693 令牌交换、RFC 9449 DPoP、RFC 9700 安全最佳实践。持有者证明是已有标准方向；本项目的请求证明是参照 DPoP 思路的国密私有 profile，不与标准 DPoP 互通。

2.2 SM2 门限与协同签名

写作指引：SM2 签名 $s = (1 + d)^{-1}(k + r) - r$ 中含有 $(1 + d)^{-1}$，不能像 Schnorr 那样把份额线性相加，这是 SM2 门限化的难点。按以下脉络写：两方协同签名 [9]；无可信中心的门限方案 [10]；基于同态加密与零知识证明、可识别中止的方案 [11, 12]。明确写出：两方 SM2 协同签名本身是已有技术，并已在移动端等场景广泛使用；本文采用其中最简洁的两方乘法分享结构，贡献**不在**签名算法本身，而在于份额释放条件与 OAuth 授权状态的绑定，以及与受理事务、效果端、支付的组合。

2.3 AI 代理的行动审批与门限签名

写作指引：重点写 KITA[15]。KITA：提议者不持有份额，多个 LLM 评审者审查同一规范化授权对象，审查通过后签名服务释放份额，最终形成门限 BLS 签名，采用 DKG。有外部评审指出其安全论证中审批通道没有被建模（引用时注明这是外部观察）。与本文的区别用下表说明。

表 1: 现有方案的通常做法与本原型的组合边界

类型	通常做法与来源	本项目的不同
模型护栏	Llama Guard 2 对输入输出作安全分类，概率阈值与模型存在局限 [18]	以授权边界作确定性检查，不要求先识别攻击；代理仍为确定性脚本。
OAuth	Bearer 持有即可使用 [17]；DPoP 已支持令牌绑定密钥 [2]	组合请求体绑定、委托降权与祖先共享预算，并非发明持有者证明。
代理支付	AP2 用用户意图及付款授权约束交易，已有金额等约束 [19]	将委托链、共享预算与 SM2 协同批准接入本地 x402 流程。

2.4 证书状态与透明日志

写作指引：为第 4.9的设计铺垫：证书吊销列表 [4]、OCSP 及其装订 [5]、证书透明日志 [6] 都在解决“如何让验证方确认凭据此刻未被吊销”。本文的撤销名单快照借用同类成熟构件，新意在于把状态纪元绑定进检查协同签名的被签消息，并作用于多级委托链。两三句即可，不要展开。

2.5 AI 代理支付

写作指引：x402 [16] 用 HTTP 402 承载支付要求与支付证明，V2 支持扩展与自定义 scheme。说明其付款要求与证明机制；AP2 已有用户意图与付款授权约束，不能泛化为支付协议不检查用户授权。本文让付款意图须经协同签名批准（第 4.7），链上结算签名仍为 EIP-3009。

3 系统模型与威胁模型

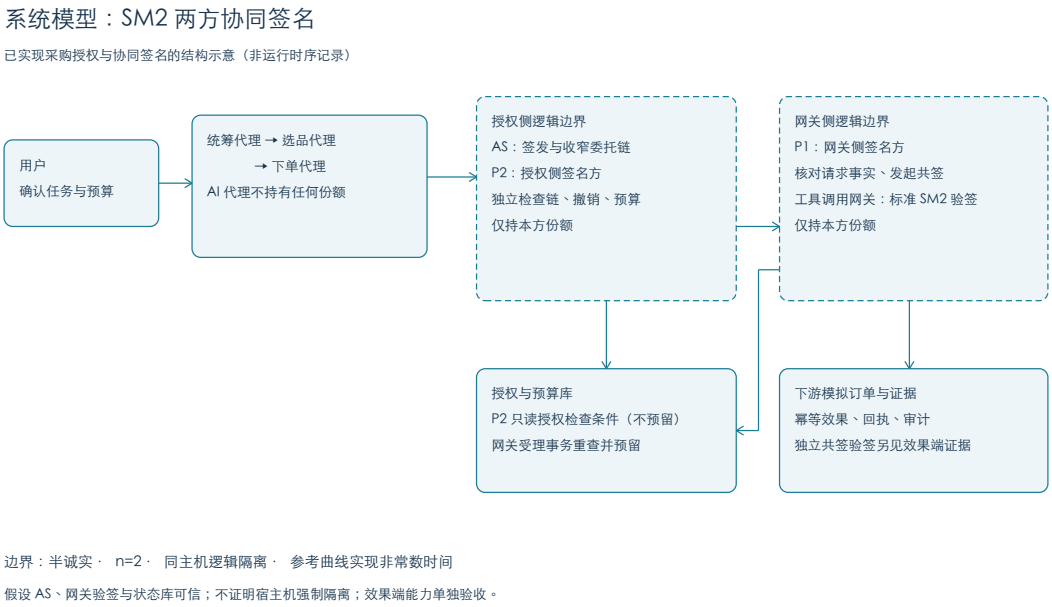


图 1: 系统模型与签名方逻辑边界。AI 代理不持有任何签名份额。

3.1 参与方

写作指引：按图 1逐一介绍：用户；统筹、选品、下单三个 AI 代理（只能提出请求）；AS（统一签发各级 SM2 令牌，委托只能收窄）；授权侧签名方 P_{A}（与 AS 位于同一逻辑边界，持份额 d_2，使用只读数据库角色）；工具调用网关与网关侧签名方 P_{E}（持份额 d_1）；授权与预算库（PostgreSQL，受理事务）；下游订单服务（独立数据库，独立验签）；回执与审计。

3.2 威胁模型

假设 1 (敌手能力)**.** 敌手可以：(1) 完全控制所有 AI 代理，包括让其提出任意请求、复制任意令牌；(2) 攻破 P_{E}（含网关）、P_{A} 中**至多一个**，获得其份额并以半诚实方式运行该方的协议；(3) 观察和重放网络消息。

假设 2 (信任基础)**.** AS 的签名私钥与身份登记可信；下游订单服务的验签代码可信；SM2 满足 EUF-CMA 安全，SM3 可视为随机预言机。

说明. 假设 1 (1) 已经把 AI 代理视为完全受敌手控制，因此无论代理是确定性脚本还是真实大模型，本文的安全目标与论证都不变。受提示注入影响的大模型提出越权请求，只是 (1) 的一个具体实例。本文实验中的代理为确定性脚本；接入真实大模型、实测"模型被诱导"与"越权实际生效"之间差距的计划见第 9。

写作指引：必须写明不在范围内的情况：两方同时被攻破；恶意（非半诚实）参与方；侧信道（原型的标量乘不是常数时间）；同一主机、同一操作系统用户的部署（演示环境）。网关被攻破时的结论见命题 2，不得扩大为"网关被攻破后任何订单都无法产生"。

4 方案设计

4.1 基础：委托授权与持有者证明

写作指引：简要介绍已有系统：授权码 + PKCE 获得根令牌；两次令牌交换，每次由 AS 签发收窄后的子令牌（金额、工具、期限、次数、深度逐维比较）；下单代理每次调用附带请求证明，用自己的 SM2 私钥签名，并以 SM3 绑定令牌与完整请求体；网关在受理事务内复核祖先撤销状态与共享预算；执行与恢复保证同一意图只产生一次效果。控制在一页以内，并注明这部分是"基础机制"。

4.2 授权行动对象

每一次需要批准的高风险操作都被规范化为行动对象 act，包含租户、任务、完整的根到叶授权路径、持有者与密钥标识、受众、工具及版本、业务幂等键、请求与报价标识、商品条目、收货对象、金额（整数分）、参数摘要、策略版本、密钥纪元、过期时间与支付意图摘要（无支付时为全零哨兵值）。签名消息为

$$M = \texttt{"AGENT-GUARD-COSM2-ACTION-V1\textbackslash n"} \,\|\, \mathrm{CanonicalJSON}(\mathsf{act}).$$

域分离前缀防止与令牌、请求证明及旧版门限消息之间的跨协议重用；字段顺序固定、解析严格（拒绝重复字段、未知字段与非规范编码）。验签方案（本方案或旧版 FROST）由服务端配置决定，客户端无法选择。

4.3 两方协同 SM2 签名

记 SM2 曲线的阶为 n、基点为 G，用户标识固定为 1234567812345678。

密钥生成（无可信分发者）。 P_{E} 随机选取 $d_1 \in [1, n-1]$，发送 $T_1 = d_1^{-1}G$；P_{A} 随机选取 $d_2 \in [1, n-1]$，计算公钥 $P = d_2^{-1}T_1 - G$。此时 $(1+d)^{-1} \equiv d_1 d_2 \pmod{n}$，完整私钥 d 从不出现在任何一方。生成后对固定确认消息执行一次完整签名并以标准实现验签，通过后才写入份额（文件权限 0600）。

签名。 见图 2。双方各自由结构化行动计算 $e = \mathrm{SM3}(Z_A \| M)$，$P_{\mathsf{A}}$ 不接受由 P_{E} 提供的 e。

1. P_{E}：先核对 act 与经请求证明验证的请求事实一致（授权检查条件 Φ_{E}）；$k_1 \xleftarrow{\$} [1, n-1]$，发送 $Q_1 = k_1 G$、act 与叶令牌。
2. P_{A}：**先检查授权检查条件** $\Phi_{\mathsf{A}}(\mathsf{act})$（第 4.4），不成立则拒绝并终止；校验 Q_1 在曲线上且非无穷远点；$k_2, k_3 \xleftarrow{\$} [1, n-1]$，$(x_1, \cdot) = k_3 Q_1 + k_2 G$，$r = (e + x_1) \bmod n$（$r = 0$ 时重取），$s_2 = d_2 k_3$，$s_3 = d_2(r + k_2)$；发送 (r, s_2, s_3) 后销毁 k_2, k_3，不保留跨轮状态。
3. P_{E}：$s = d_1 k_1 s_2 + d_1 s_3 - r \bmod n$；若 $s = 0$ 或 $s = n - r$ 则重新开始；用 P 做标准 SM2 验签，通过后输出 (r, s)；无论成败均销毁 k_1。

引理 1 (正确性)**.** *令 $k = k_1 k_3 + k_2$，则 $s = (1+d)^{-1}(k + r) - r \bmod n$，$(r, s)$ 是消息 M 在公钥 P 下的标准 SM2 签名。*

证明. x_1 是 kG 的横坐标；$s = d_1 d_2 (k_1 k_3 + k_2 + r) - r = (1+d)^{-1}(k + r) - r$。 □

4.4 授权检查条件

$$\begin{aligned}\Phi_{\mathsf{A}}(\mathsf{act}, t) = {} & \mathsf{ChainValid} \wedge \mathsf{PathMatch} \\ & \wedge \mathsf{InScope} \wedge \mathsf{PolicyMatch} \\ & \wedge \mathsf{NotRevoked}(t) \wedge \mathsf{NotExpired}(t) \wedge \mathsf{BudgetOK}(t)\end{aligned}$$

授权侧签名方依次检查：策略版本、受众、密钥纪元与有效期上界（AUTHZ_POLICY_MISMATCH / AUTHZ_EXPIRED）；用 AS 公钥验证根到叶的签名链，并核对路径、租户、任务、持有者与密钥标识（AUTHZ_PATH_MISMATCH）；工具与参数在令牌范围内（AUTHZ_SCOPE）；再在只读事务中读取路径上每个节点的当前状态，依次检查是否被撤销、是否过期、剩余额度与调用次数是否足够（AUTHZ_REVOKED / AUTHZ_EXPIRED / AUTHZ_OVER_BUDGET）。撤销检

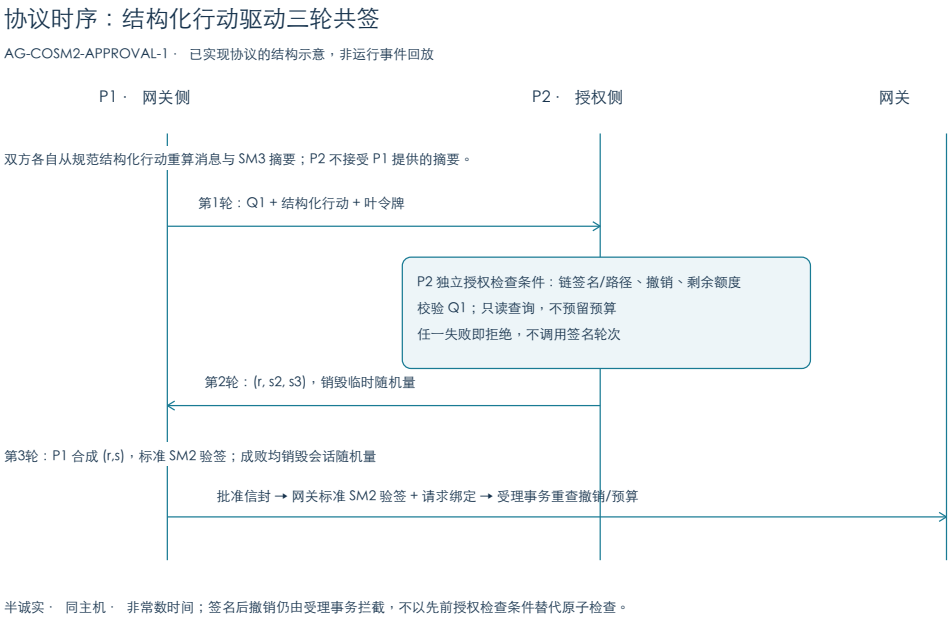


图 2: 授权检查条件的两方协同 SM2 签名流程

查先于额度检查，避免根节点额度耗尽掩盖中间节点的撤销。任一检查失败都不会进入曲线运算。

写作指引：强调两点：（1）授权侧签名方只读、不预留，预算的真正预留仍在网关受理事务中原子完成；（2）授权侧签名方使用仅有 SELECT 权限的数据库角色，写入已被实测拒绝。

4.5 与受理事务的组合

网关先验 SM2 令牌与请求证明，再以标准 SM2 实现验证共签签名，随后在受理事务内把行动与实际订单、可信报价、授权路径逐项比对，原子写入 action_id 到操作的不可覆盖绑定，并在锁后按数据库时钟再检查一次过期。由此得到两层撤销保护：**签名前撤销**由授权侧签名方拒绝出份额（不产生任何签名）；**签名后撤销**由受理事务拒绝。

4.6 效果端独立验签

网关在转发订单时附带原始批准信封。下游订单服务以配置的公钥独立执行标准 SM2 验签，核对金额、商品、报价与业务幂等键与其收到的业务意图一致，并在自身数据库中以唯一约束记录“行动—业务键—操作”绑定，拒绝同一批准用于另一操作。首次执行与未知结果后的恢复都转发同一原始信封。

写作指引：写明边界：效果端只复核签名、业务意图与一次性绑定，不查询 AS 的当前撤销与预算、不重做有效期判断；这一点由第 4.9的设计解决。

4.7 付款批准（协同签名）

在 x402 支付流程中，行动对象的支付意图摘要覆盖收款方、网络、资产、金额、资源地址与报价有效期；适配器只接受与之完全一致的 402 报价。因此更换收款方、金额或网络都需要新的协同签名。链上结算仍使用 EIP-3009（secp256k1）签名，本文不替换结算算法。

4.8 推广到 t-of-n 访问结构（设计）

写作指引：这一小节是**设计**，标题和正文都要写明“尚未实现”。要点：（1）推广的目的是可用性，即某个参与方宕机时仍能签名；（2）为保证撤销不可绕过，授权侧签名方必须是必选方，访问结构为“授权侧签名方 $\wedge$（其余 $n-1$ 个参与方中任意 $t-1$ 个）”，而不是简单的 t-of-n；（3）对“授权侧签名方 $\wedge$（网关侧签名方 $\vee$ 审计方）”这一特例，可由网关侧签名方与审计方复制持有同一份额而复用两方协议；一般情形可基于 [11, 12] 实现，代价是引入同态加密或零知识证明；（4）若要求“未入账即无法执行”，审计方须为必选方，可扩展为三方乘法分享。

4.9 撤销名单快照：可离线验证的撤销新鲜度（设计）

本节为设计，尚未实现。现有方案中，签名之后发生的撤销只能由网关查询数据库拦截；若网关失陷，已签出的批准在有效期内仍可被执行（命题 2）。为此，我们让签名携带“它是在哪一版授权状态下签出的”，并使该事实可被第三方离线验证。

状态检查点。 AS 以周期 Δ 发布检查点

$$\mathsf{CP}_\epsilon = \big(\epsilon,\ \tau_\epsilon,\ R_\epsilon,\ \sigma_\epsilon\big), \qquad \sigma_\epsilon = \mathrm{SM2.Sign}_{sk_{\mathrm{AS}}}\big(\texttt{CP-DOMAIN} \,\|\, \epsilon \,\|\, \tau_\epsilon \,\|\, R_\epsilon\big),$$

其中 ϵ 为单调递增的纪元号，τ_ϵ 为发布时间，R_ϵ 为截至该纪元全部已撤销授权节点标识按序排列后构成的 SM3 默克尔树根。有序树使“某标识不在集合中”可以用相邻两叶及其路径证明（非成员证明）。

绑定进签名。 授权侧签名方在核验授权检查条件时读取最新检查点 CP_ϵ，将 (ϵ, R_ϵ) 写入行动对象，并为授权路径上每个节点生成非成员证明 π 随信封携带。由于 (ϵ, R_ϵ) 处于被签消息内，网关侧签名方与网关都无法将其替换为旧状态。

离线验证。 下游订单服务与收款方持有 AS 公钥与最新检查点 CP_{ϵ^*}，验证：（i）共签签名有效；（ii）σ_ϵ 有效；（iii）π 证明路径节点不在 R_ϵ 中；（iv）$\epsilon^* - \epsilon \le k$。任一不满足即拒绝，无需访问 AS 数据库。

预期性质。 若撤销在时刻 t_r 提交并于下一检查点公开，则之后签出的批准无法通过（iii），之前签出的批准在 $\epsilon^* - \epsilon > k$ 后无法通过（iv）。因此网关失陷时，“签名后撤销”的可利用窗口由批准有效期收紧为约 $(k+1)\Delta$ 加时钟偏差，且该界限可由第三方验证；

授权侧签名方“路径未被撤销”的判断也从“只能相信授权侧签名方”变为“可由 AS 签名的状态独立复核”。

写作指引：写作时保持克制：（1）明确这是设计、无实验数据；（2）说明检查点分发需要验证方能取得最新纪元（如从公开日志拉取），这是新的可用性依赖；（3）说明与 CRL/OCSP 装订/证书透明 [4, 5, 6] 的关系：构件成熟，新意在绑定方式与作用对象；（4）可复用项目已有的 SM3 审计检查点基础设施。

5 安全性分析

定义 1 (执行授权不可伪造性)**.** 在假设 1 and 2下，考虑如下游戏：敌手与系统交互，可以请求任意行动的共签。若敌手最终让验签方接受了某个行动 act^*，而在所有对 act^* 的签名会话中，诚实参与方的授权检查条件均不成立（或从未有诚实参与方参与 act^* 的会话），则敌手获胜。若任何多项式时间敌手的获胜概率均可忽略，则称方案满足执行授权不可伪造性。

定理 1. *若两方协同签名协议在半诚实模型下安全地实现了 SM2 签名功能，且 SM2 满足 EUF-CMA，则本文方案满足定义 1。*

写作指引：证明分两种情况写，每种情况都归约到 SM2 的不可伪造性。

证明思路. 情况一：敌手攻破 P_{E}。由于 P_{A} 只对授权检查条件成立的行动参与签名，并且自行由 act 计算 e，敌手从协议中得到的只是授权检查条件成立行动上的签名。若敌手能为 act^* 产生有效签名，可构造伪造者 $\mathcal{B}$，利用协议的模拟器把它转化为对 SM2 签名谕言机的伪造。情况二：敌手攻破 P_{A}。对称地，P_{E} 只对与经过验证的请求事实一致的行动发起会话。【待填：C 补全：引用所采用协议的安全性证明（[9] 或替代文献），说明模拟器如何构造】。 □

命题 1 (效果唯一性)**.** *在假设 2下，每个有效共签批准至多产生一次业务效果。*

证明思路. 下游订单服务以唯一约束记录行动、业务键与操作的绑定，并在创建效果前于同一事务中检查；同一批准用于另一操作违反唯一约束而被拒绝，同一操作的重试返回已有结果。 □

命题 2 (网关失陷的影响上界)**.** *若敌手攻破网关（含网关侧签名方份额），则：(1) 敌手无法为授权侧签名方未核准的行动产生有效签名；(2) 由命题 1，每个已核准行动至多执行一次；(3) 签名之后才发生的撤销在批准有效期内不能被效果端发现。*

写作指引：(3) 是如实陈述的剩余风险，对应第 4.9的设计。不得写成“网关被攻破后任何订单都无法产生”。

写作指引：可选：用 ProVerif 或 Tamarin 对“委托—出份额—撤销—接受”流程建模，验证一条可达性性质（撤销后不存在被接受的新行动）。只有真正跑出结果才写，否则不写。不要写“已形式化证明安全”。

不覆盖的情况。 两方同时被攻破；恶意参与方（需引入零知识证明）；侧信道；拒绝服务（任一签名方离线即无法签名，第 4.8的推广用于缓解）。

6 实现

系统以 Python 3.11 实现，SM2/SM3 使用 tongsuopy 1.0.1（铜锁 8.3.2），数据库为 PostgreSQL 16。网关、网关侧签名方与下游订单服务的最终验签均调用铜锁的标准 SM2 实现；自写的曲线运算只用于计算份额，且产出的公开测试向量已由 OpenSSL 3 `pkeyutl -verify` 独立验证（篡改一个字节即失败）。授权侧签名方以独立子进程运行，只读取本方份额。

表 2: 实现概况（规模为源代码行数，`wc -l`，提交 27c722a）

模块	位置	行数	状态
协同签名核心、份额、两方服务	`src/agent_guard/cosign/`	858	本轮实现
其中授权侧签名方授权检查条件签名者	`cosign/authz_domain.py`	142	本轮实现
其中效果端验签	`cosign/effect.py`	74	本轮实现
批准编码与方案切换	`src/agent_guard/threshold/`	941	扩展
委托授权基础	`src/agent_guard/authorization/`	5667	已有
受理事务、预算与执行恢复	`ledger/`、`execution/`	5500	已有

7 实验评估

写作指引：只报告实际跑出来的结果。小样本报告中位数和 p95，不报告“提升百分之多少”。历史证据、本轮真实运行和示意图分开呈现。

7.1 实验环境

宿主机为 Apple M5 Pro（arm64），实验在固定的 linux/amd64 Docker 镜像中以仿真方式运行（Python 3.11.17、tongsuopy 1.0.1）；数据库为独占的 PostgreSQL 16.15 实例。基准测试期间宿主机同时运行其他隔离测试，未控制 CPU 频率与隔离，因此数据只用于各阶段相对比较，不作生产性能结论。代码提交为 27c722a。【待填：内存大小】

7.2 正确性与攻击拒绝

功能正确性方面：核心库单元测试 76 项（含 50 组随机密钥签名均被铜锁验签通过）；协同签名采购集成用例 16 项；包含旧执行路径、门限、两方与效果端的完整数据库集成回归 552 项；x402 相关 142 项；以上全部通过并经独立复验。攻击结果见表 3与图 3。

表 3: 攻击与拒绝位置。协同签名各行来自固定运行 01af29ac-26be-4616-851d-d8afa38fa46e；“盗用令牌”另见场景 1 运行 8b6868d7；“委托扩权”来自场景 3 运行 a05a8544

攻击	拒绝位置	拒绝码	新订单数	预算变化
盗用令牌（无私钥）	网关（持有者证明）	INVALID_SIGNATURE	0	0
委托扩权（金额 / 工具）	AS	invalid_request（HTTP 400）	0	0
行动越权（超出令牌范围）	**授权侧签名方**	AUTHZ_SCOPE	0	0
撤销后再请求共签	**授权侧签名方**	AUTHZ_REVOKED	0	0
共签后撤销	受理事务	REVOKED（HTTP 403）	0	0
仅网关侧签名方伪造签名	网关验签	INVALID_SIGNATURE（HTTP 401）	0	0
签名后篡改金额	网关（批准与订单比对）	APPROVAL_MISMATCH（HTTP 409）	0	0
超出剩余预算	**授权侧签名方**	AUTHZ_OVER_BUDGET	0	0
绕过网关直接调用下游	下游订单服务	DOWNSTREAM_UNAUTHORIZED	0	0
合法共签（对照）	—	HTTP 202	1	【待填：预留金额】



图 3: 负例矩阵（固定运行 01af29ac；空格表示该位置未被触发，不作结论）

写作指引：表中“行动越权”与“委托扩权”是两种不同攻击：前者是执行时请求的工具或参数超出令牌范围，由授权侧签名方拒签；后者是申请子授权时要求更大权限，由 AS 拒绝签发。正文要分开解释。

7.3 性能

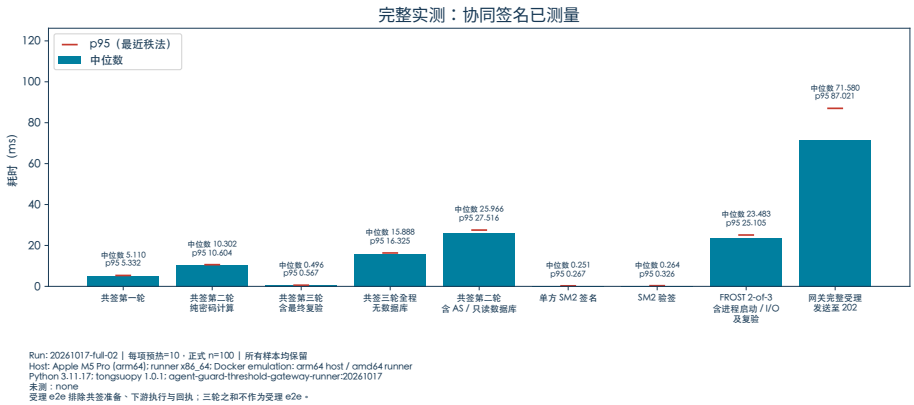


图 4: 协同签名各阶段与对照方案的耗时（每项预热 10 次、正式 100 次，失败 0）

表 4: 耗时统计（单位：ms；来源 experiments/cosm2_bench/results/20261017-full-02）

测量项	样本数	中位数	p95	说明
协同签名 round1（网关侧签名方）	100	5.11	5.33	一次标量乘
协同签名 round2（授权侧签名方，不含授权检查条件）	100	10.30	10.60	两次标量乘
协同签名 round3（合成并验签）	100	0.50	0.57	含铜锁验签
协同签名三轮合计（不含授权检查条件）	100	15.89	16.33	纯 Python 原型
授权侧签名方 round2（含授权检查条件核验）	100	25.97	27.52	真实 AS 签名链 + 只读事务
单方 SM2 签名（铜锁）	100	0.25	0.27	对照
SM2 验签（铜锁）	100	0.26	0.33	对照
FROST 2-of-3 组签名	100	23.48	25.11	含子进程启动与 I/O
网关受理（HTTP 至 202）	100	71.58	87.02	不含共签准备与下游执行

写作指引：分析要点：（1）协同签名的主要开销是纯 Python 的标量乘，与单方签名的差距主要来自实现而非协议轮数，换用常数时间原生实现可显著降低；（2）授权侧轮次中授权检查条件核验（AS 签名链验证与只读事务）约占 16 ms，是真正的“把关成本”；（3）共签准备（约 5.1+26.0+0.5 ms）与网关受理（71.6 ms）是分开计时的，二者相加可作为一次共签下单在网关侧的粗略开销，但不是同一次测量；（4）仿真环境与并发负载会抬高绝对值，只比较相对量。

7.4 演示

写作指引：从 media/current/ 中选 1–2 张：cosign-live.png（协同签名真实运行结果，带 run_id）与 cosign-authz-refusal-illustrative.png（授权侧签名方拒签示意）。图注写明“现场运行”或“动画示意”。另有 185 秒真实运行录屏 cosm2-live-tour.mp4 可作为附件。

8 讨论与局限

1. 仅实现 $n = 2$；t-of-n 访问结构为设计（第 4.8）。
2. 安全模型为半诚实；恶意安全需要零知识证明，尚未实现。
3. 演示中两方位于同一主机、同一操作系统用户，授权侧签名方为独立子进程并使用仅 SELECT 权限的数据库角色，这不等同于操作系统级强隔离。
4. 份额计算的标量乘不是常数时间；Python 不能保证内存中秘密被物理擦除。
5. 网关失陷时，签名之后的撤销在批准有效期内不能被效果端发现（命题 2）；撤销名单快照（第 4.9）为设计，尚未实现。
6. x402 部分为本地测试链与测试资产，链上结算签名仍为 EIP-3009。
7. 复赛阶段的 AI 代理为确定性脚本，未接入真实大模型，因此尚无模型在提示注入下实际行为的数据；接入计划与实验设计见第 9。规模化实验尚未完成。
8. 性能数据来自仿真环境且未控制并发负载，不作生产吞吐结论。

9 后续工作

写作指引：本节全部是计划，没有任何实测数字。实现并取得数据之前，不得把本节内容写进摘要、贡献列表或实验评估；数字出来后整段移入实验评估一节（第 7），并注明运行编号、模型版本与样本数。

撤销名单快照与访问结构。 按优先级，决赛前首先实现第 4.9 的撤销名单快照，把签名之后的撤销窗口收紧到可离线验证的 $k\Delta$；其次推广到授权侧签名方必选的三方访问结构（第 4.8）；再用 ProVerif/Tamarin 对“撤销后不存在新接受”建模，并评估恶意模型下零知识证明的需求与代价。

真实大模型代理与提示注入实验（计划，未实现）

动机。 本文论证的前提是“AI 代理可被完全控制”（假设 1），但复赛实验中的代理是确定性脚本，越权请求由测试主动构造。接入真实大模型后，可以在同一套系统上分开测量两件事：模型在提示注入下**提出**越权意图的频率，以及这些意图**实际产生**业务效果的次数。本文主张的是后者为零，而不是模型不会被诱导。

接入方式。 统筹、选品、下单三个 AI 代理改由大模型通过工具调用驱动。模型运行在持证进程之外，只能输出结构化意图（工具标识与参数）。持证进程先按工具目录的参数模式做校验，再构造请求体、签署请求证明；控制通道不提供导出令牌、私钥或签名的命令。因此模型不持有任何凭据，网关、授权侧签名方与协同签名协议均不作改动，确定性脚本保留为对照组。主实验使用 DeepSeek API，另配一个约 1B 参数的本地离线模型，用于现场断网时保证演示可运行；两类模型的结果分开报告，不合并统计。

实验设计。 在报价文档中嵌入恶意指令，覆盖多买数量、改收货对象、要求未授权工具、超出预算、诱导原样重放等类别，并配正常文档作对照。固定模型版本、提示词与采样参数，每类重复多次，保存模型原始输出。报告三项指标：

1. **越权意图率**：模型提出越权意图的运行占比（如实报告，可能很高）；
2. **越权效果数**：越权意图最终产生的订单、付款与预算变化，以及每次的拒绝位置与拒绝码；
3. **合法任务完成率**：正常文档下任务被正确完成的比例，用于说明安全机制没有以牺牲正常业务为代价。

边界。 本文不声称防止提示注入本身；模型输出的非确定性如实标注；样本数、模型版本与运行编号随结果一并给出；未达到预定样本量时不报告比例。

10 结论

写作指引：3–4 句：重述“先查授权再签名”的主张；已实现了什么（两方协同 SM2、与受理事务/效果端/支付的组合）、证据是什么（16 个集成用例、552 项回归、9 类攻击、独立复验、OpenSSL 互验）；下一步按优先级：撤销名单快照、授权侧签名方必选的访问结构、恶意安全与形式化验证、真实大模型代理与提示注入实验（第 9）。最后一句可以落在“模型可以被骗，但越权的事做不成”这一主张上，但必须写成“将在决赛前实测”，不能写成已证实。

参考文献

[1] M. Jones, A. Nadalin, B. Campbell, et al. OAuth 2.0 Token Exchange. RFC 8693, 2020.

[2] D. Fett, B. Campbell, J. Bradley, et al. OAuth 2.0 Demonstrating Proof of Possession (DPoP). RFC 9449, 2023.

[3] T. Lodderstedt, J. Bradley, A. Labunets, D. Fett. Best Current Practice for OAuth 2.0 Security. RFC 9700, 2025.

[4] D. Cooper, S. Santesson, S. Farrell, et al. Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. RFC 5280, 2008.

[5] S. Santesson, M. Myers, R. Ankney, et al. X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP. RFC 6960, 2013.

[6] B. Laurie, A. Langley, E. Kasper. Certificate Transparency. RFC 6962, 2013.

[7] 国家市场监督管理总局, 国家标准化管理委员会. GB/T 32918–2016 信息安全技术 SM2 椭圆曲线公钥密码算法.

[8] GB/T 32905–2016 信息安全技术 SM3 密码杂凑算法.

[9] 尚铭, 马原, 林璟锵, 荆继武. SM2 椭圆曲线门限密码算法. 密码学报, 2014, 1(2): 155–166. 【待填：C 核对卷期页码，并确认其中两方签名结构与本文一致；若不一致，换成实际采用的协议来源】

[10] 【待填：作者】. A SM2 Elliptic Curve Threshold Signature Scheme without a Trusted Center. KSII Transactions on Internet and Information Systems, 2016.

[11] 【待填：作者全名】 Liang, Chen. Non-interactive SM2 threshold signature scheme with identifiable abort. Frontiers of Computer Science, 2024.

[12] 【待填：作者】. Faster threshold-SM2 with identifiable abort and non-interactive online signing. Cybersecurity, 2025.

[13] C. Komlo, I. Goldberg. FROST: Flexible Round-Optimized Schnorr Threshold Signatures. SAC 2020.

[14] D. Connolly, C. Komlo, I. Goldberg, C. A. Wood. The Flexible Round-Optimized Schnorr Threshold (FROST) Protocol for Two-Round Schnorr Signatures. RFC 9591, 2024.

[15] Y. Zheng, Q. Zhang. From Review to Authorization: Key-Isolated Threshold Signing for LLM Agents. arXiv:2609.05901, 2026.

[16] x402 Foundation. x402 Protocol Specification v2. `https://github.com/x402-foundation/x402`, 提交 faa1c694c66a3732aaabbce93bdae140e521a67d. 【待填：查阅日期】

[17] M. Jones, D. Hardt. OAuth 2.0 Bearer Token Usage. RFC 6750, 2012. `https://datatracker.ietf.org/doc/html/rfc6750`.

[18] Meta. Llama Guard 2 Model Card. `https://github.com/meta-llama/PurpleLlama/blob/main/Llama-Guard2/MODEL_CARD.md`, 查阅日期 2026-10-19.

[19] AP2. Agent Payments Protocol Specification. `https://ap2-protocol.org/ap2/specification/`, 查阅日期 2026-10-19.